Relatório de Auditoria

Mercadinho Brisa Mar

Data: 04/11/2026
Escopo: segurança, funcionamento e UX/interface
Stack: Next.js 15, React 19, TypeScript, Tailwind CSS, Google Maps

Metodologia: inspeção do código rastreado, configuração, assets, referências de segurança e scripts disponíveis. Não foram inferidos problemas além das evidências encontradas.

Resumo executivo

Foram confirmados 5 achados: 1 média, 3 baixas e 1 informativa. Não foram identificados handlers de backend, banco, autenticação, isolamento de dados, IDOR ou sinks de XSS no código auditado.

Severidade	Quantidade
Média	1
Baixa	3
Informativa	1

Pontos positivos

Uso de rel="noopener noreferrer" nos links externos; ausência de HTML injetado, eval/new Function e endpoints próprios; chave do Google Maps referenciada por variável NEXT_PUBLIC em vez de valor literal; TypeScript com erros de build não ignorados.

Principais fragilidades

Assets locais usam caminhos públicos incorretos; o mapa aceita chave vazia e pode falhar em produção; o documento está marcado como inglês; Facebook e Instagram apontam para #.

Achados verificados

MÉDIA - Imagens locais não carregam (Funcionamento / UX)

Local: components/mercadinho-brisa-mar.tsx:93, 112, 121, 192, 200, 208
Evidência: As referências usam /public/... e /src/... . No Next.js, arquivos em public são servidos a partir de / e arquivos em src/assets não são URLs públicas sem importação. As imagens de hero, galeria e serviços ficam quebradas em produção.
Correção: Mover os assets para public/assets e referenciar /assets/... ou importar imagens de src/assets via next/image.

BAIXA - Mapa pode falhar silenciosamente (Funcionamento)

Local: components/mercadinho-brisa-mar.tsx:11, 160
Evidência: NEXT_PUBLIC_GOOGLE_MAPS_API_KEY usa fallback vazio e é passado ao APIProvider. Sem variável configurada ou com restrição inválida, o mapa não renderiza corretamente.
Correção: Validar a configuração no deploy e exibir estado alternativo com endereço/link quando a chave estiver ausente; restringir a chave por domínio e APIs.

BAIXA - Idioma declarado incorretamente (UX / acessibilidade)

Local: app/layout.tsx:15
Evidência: O conteúdo está em português, mas o elemento html declara lang="en". Leitores de tela e mecanismos de busca podem aplicar pronúncia e classificação erradas.
Correção: Alterar para lang="pt-BR".

BAIXA - Links sociais sem destino (Funcionamento / UX)

Local: components/mercadinho-brisa-mar.tsx:300-301
Evidência: Facebook e Instagram usam href="#", levando o usuário ao topo da página e simulando ações que não funcionam.
Correção: Substituir pelos perfis reais ou remover os botões até que existam URLs válidas.

INFORMATIVA - Verificação automatizada indisponível (Qualidade)

Local: package.json:scripts
Evidência: npm run lint e npm run build não puderam ser executados porque as dependências locais não estão instaladas (eslint e next não reconhecidos).
Correção: Instalar dependências com o gerenciador oficial do projeto e executar lint/build no CI.

Cobertura de segurança

Banco sem tranca: não aplicável; não há banco nem consultas. Permissões no navegador: não há operações administrativas ou sensíveis. IDOR: não há objetos/rotas de dados. Chaves expostas: nenhum segredo real foi encontrado; .env.example contém apenas placeholders. XSS/injeção: não foram encontrados innerHTML, dangerouslySetInnerHTML, eval ou new Function; o conteúdo exibido é estático.

Recomendações priorizadas

1. Corrigir imediatamente os caminhos das imagens.
2. Tornar o mapa resiliente à ausência da chave e configurar restrições da API.
3. Corrigir lang para pt-BR e remover/substituir links sociais fictícios.
4. Instalar dependências e adicionar lint/build ao CI antes do deploy.

ISSUES PARA O GITHUB

Não foram criadas issues. Abaixo estão blocos sugeridos, sem publicação automática.

Título: MÉDIA - Imagens locais não carregam
Local: components/mercadinho-brisa-mar.tsx:93, 112, 121, 192, 200, 208
Problema: As referências usam /public/... e /src/... . No Next.js, arquivos em public são servidos a partir de / e arquivos em src/assets não são URLs públicas sem importação. As imagens de hero, galeria e serviços ficam quebradas em produção.
Correção: Mover os assets para public/assets e referenciar /assets/... ou importar imagens de src/assets via next/image.

Título: BAIXA - Mapa pode falhar silenciosamente
Local: components/mercadinho-brisa-mar.tsx:11, 160
Problema: NEXT_PUBLIC_GOOGLE_MAPS_API_KEY usa fallback vazio e é passado ao APIProvider. Sem variável configurada ou com restrição inválida, o mapa não renderiza corretamente.
Correção: Validar a configuração no deploy e exibir estado alternativo com endereço/link quando a chave estiver ausente; restringir a chave por domínio e APIs.

Título: BAIXA - Idioma declarado incorretamente
Local: app/layout.tsx:15
Problema: O conteúdo está em português, mas o elemento html declara lang="en". Leitores de tela e mecanismos de busca podem aplicar pronúncia e classificação erradas.
Correção: Alterar para lang="pt-BR".

Título: BAIXA - Links sociais sem destino
Local: components/mercadinho-brisa-mar.tsx:300-301
Problema: Facebook e Instagram usam href="#", levando o usuário ao topo da página e simulando ações que não funcionam.
Correção: Substituir pelos perfis reais ou remover os botões até que existam URLs válidas.